INSTITUTIONAL IT POLICY FOR SYSTEM ADMINISTRATION

Standard Operating Procedures, Access Controls, Infrastructure Governance & Compliance for Business Schools

Document Ref: B-SCH-IT-SYSADMIN-2026	**Version:** 2.4 (Enterprise)
Effective Date: Academic Year 2026–2027	**Review Cycle:** Bi-annual / Post-Audit
Approved By: IT Governance Board & Dean	**Target Scope:** System Administrators, Network Engineers, DBAs

1. Purpose, Scope & Administrative Authority

This policy defines mandatory operational security, privileged access management, infrastructure maintenance, and disaster recovery rules for Systems Administrators, Network Engineers, and Cloud Operators within a Business School. Because management institutions govern confidential admissions data, sensitive executive compensation benchmarks, valuable proprietary case research, and high-stakes digital examination environments, system administration demands the highest tier of zero-trust verification and audit readiness.

2. Privileged Access Management (PAM) & Account Hierarchy

2.1 Principle of Least Privilege (PoLP): Full administrative ('root' or 'Domain Admin') privileges shall never be permanently assigned to individual personal accounts. Routine administrative tasks must use designated secondary admin accounts (e.g., *adm.john.doe*) requiring Hardware-bound Multi-Factor Authentication (FIDO2/WebAuthn).

2.2 Break-Glass Emergency Protocols: Root passwords for master hypervisors (VMware vSphere / Proxmox), core firewalls, and top-level cloud tenants (AWS/Azure/GCP) must be stored in a tamper-evident Enterprise Secrets Vault (e.g., CyberArk, HashiCorp Vault) governed by dual-custody authorization. Access generates immediate SMS/Email alerts to the CIO and Director.

2.3 Separation of Duties: No single system administrator shall have simultaneous unchecked control over both student grade databases (SIS/ERP) and audit/log retention servers.

3. Server Infrastructure, Virtualization & Baseline Hardening

3.1 OS Hardening: All Windows Server and Linux enterprise hosts must strictly adhere to CIS (Center for Internet Security) Level 1 Benchmark baselines before commissioning. Unnecessary services, default accounts, SMBv1, and legacy cipher suites (TLS 1.0/1.1) must be disabled.

3.2 Golden Images & Container Security: Production VMs and Docker/Kubernetes images must be built from approved, immutable base templates scanned for vulnerabilities prior to deployment. SSH access is restricted to encrypted Bastion jump-hosts using key pairs only (no password auth).

4. Specialized Academic Environments Governance

Business Schools host unique computing workloads requiring customized systems administration protocols:

Academic Facility / Workload	Key Systems Administration Mandates

Financial Trading & Analytics Labs (Bloomberg, Refinitiv, FactSet, WRDS)	• Enforce static IP binding and hardware MAC reservation. • Configure monthly API download quota alarms to prevent vendor licensing penalties. • Nightly automated wipe of temp scratch disks, cache files, and browser data.
Digital Exam & Evaluation Portals (Secure LMS, Safe Exam Browser)	• Lockdown mode: disable hyperthreading/virtual machines, clipboard access, secondary monitors. • System Admins must perform automated load testing 72h prior to peak midterm/final exam cohorts. • Dedicated isolated VLAN with whitelist-only outbound routing during live exam hours.
High-Performance Research Compute (Econometrics, Monte Carlo, ML clusters)	• SLURM/Kubernetes queue management with fair-share scheduling across faculty cohorts. • Automated scrub of scratch storage after 30 days of job completion; long-term data archived to Tier-2 S3 cold storage.

5. Patch Management, Maintenance Windows & Change Control (ITIL)

5.1 Change Advisory Board (CAB): Any modification to core switches, firewalls, SIS/LMS databases, or domain controllers requires a submitted Request for Change (RFC) including a comprehensive rollback strategy approved 48 hours in advance.

5.2 Patching Cadence:

Vulnerability Severity	CVSS Score	Testing SLA	Production Deployment SLA
Critical / Zero-Day	9.0 - 10.0	Within 12 Hours	Within 24 Hours (Emergency CAB)
High Severity	7.0 - 8.9	Within 3 Days	Within 7 Days
Medium / Routine	4.0 - 6.9	During Staging Cycle	Monthly Maintenance Window

5.3 Maintenance Windows: Routine server restarts and updates are strictly scheduled between **Saturday 23:00 and Sunday 04:00 IST**. No routine maintenance is permitted during midterm or final examination weeks.

6. Backup Architecture, RTO/RPO & Disaster Recovery

6.1 The 3-2-1-1 Backup Rule: All production data (SIS, ERP, LMS, Research Repositories) must follow the enhanced institutional standard: **3** copies of data, across **2** different media formats, **1** copy off-site (secondary campus or cloud), and **1** copy stored completely offline or on an **Immutable/WORM** (Write Once, Read Many) air-gapped target to mitigate ransomware.

System Tier	Target Workload	RPO (Max Data Loss)	RTO (Max Downtime)
Tier 1 (Mission-Critical)	SIS, ERP, Live Exam Engine, Cloud SSO	≤ 15 Minutes	≤ 2 Hours
Tier 2 (Academic Core)	LMS Archives, Library Databases, File Shares	≤ 4 Hours	≤ 8 Hours
Tier 3 (Ancillary)	Alumni Portal, Print Servers, Public CMS	≤ 24 Hours	≤ 24 Hours

6.2 Restore Testing: Automated synthetic restores must execute weekly. Full bare-metal disaster recovery drills must be conducted bi-annually and signed off by the Head of IT Systems.

7. Centralized Auditing, SIEM & Retention Standards

7.1 Universal Syslog Forwarding: System administrators must configure all switches, firewalls, active directory domain controllers, VPN concentrators, and database engines to forward audit logs in real-time to a central SIEM (Security Information and Event Management) server.

7.2 Tamper-Resistance & Retention: Audit logs must be encrypted, checksum-verified (SHA-256), and retained for a minimum of **365 days** in compliance with educational regulatory directives (e.g., UGC/AICTE, FERPA, GDPR). Logs cannot be truncated, edited, or deleted even by root administrators.

8. Administrator Code of Ethics & Sanctions

System administrators operate in a position of trust. Administrators are expressly prohibited from inspecting student or faculty mailboxes, research folders, or private communications without written authorization from the Dean and Legal Counsel. Intentional bypassing of logging, unauthorized privilege escalation, or sharing of institutional keys is subject to summary termination and prosecution under national cyber laws (e.g., Information Technology Act / Computer Fraud and Abuse Act).

Prepared By:	**Reviewed By:**	**Approved By:**
Lead Systems Administrator Infrastructure & Cloud Engineering	Chief Information Security Officer (CISO) IT Governance Board	Director / Dean Executive Academic Council
Signature: _____	Signature: _____	Signature: _____